

Windows 进程安全上下文与桌面会话诊断工具需求说明

1. 工具名称

Windows 进程安全上下文与桌面会话诊断工具

建议工程名：

WinProcessSecurityInspector

简称：

WPSI

2. 建设背景

在 Windows 10/11 环境中，桌面应用、后台服务、浏览器、WFP 访问控制组件可能运行在不同的：

- 用户身份；
- Session；
- 完整性级别；
- UAC 提升状态；
- Window Station；
- Desktop；
- 进程优先级；
- Job Object；
- AppContainer。

这些差异可能导致以下问题：

- 程序开机自启动后功能异常；
- 手工“以管理员身份运行”后恢复正常；
- 无法控制浏览器窗口；
- SendInput、SetForegroundWindow、窗口消息操作失败；
- 服务进程无法弹出用户可见窗口；
- WFP 获取到的浏览器 PID 不是浏览器主进程；
- 浏览器认证页面无法打开或无法刷新；
- 不同用户或不同 Session 之间的 IPC、窗口交互失败；
- 程序权限不足但现场无法快速定位。

本工具用于采集并对比 Windows 进程的安全上下文、桌面会话和进程启动关系，自动识别潜在权限、Session 隔离和浏览器进程定位问题。

3. 建设目标

本工具应实现以下目标：

1. 采集指定进程的完整安全上下文；
2. 对比当前应用、访问控制程序、交互用户和目标浏览器之间的权限差异；
3. 识别浏览器主进程、子进程和顶层窗口之间的关系；
4. 判断进程是否具备桌面交互条件；
5. 自动生成明确的风险、异常和建议；
6. 支持命令行、图形界面和文件导出；
7. 能够作为独立诊断工具使用，也能作为库集成到 `xianc2` 中；
8. 为现场问题提供可复现、可对比、可归档的诊断证据。

4. 适用对象

工具主要面向以下进程：

- `xianc2.exe`
- `fjAccessControl.exe`
- Windows Service
- `explorer.exe`
- `chrome.exe`
- `msedge.exe`
- `firefox.exe`
- 其他受控浏览器
- WFP 事件中获得的源进程
- 用户指定的任意 PID 或进程名称

5. 运行模式

工具应支持三种运行模式。

5.1 当前环境诊断模式

自动分析当前登录用户及相关进程，包括：

当前诊断工具进程
`explorer.exe`
`xianc2.exe`
`fjAccessControl.exe`
主流浏览器进程
当前前台窗口所属进程

示例：

```
wpsi.exe inspect
```

5.2 指定进程诊断模式

支持按 PID 或进程名诊断。

```
wpsi.exe inspect --pid 4520
```

```
wpsi.exe inspect --name chrome.exe
```

支持同时指定多个进程：

```
wpsi.exe compare --pid 4520 --pid 6688
```

5.3 浏览器访问诊断模式

输入 WFP 获取到的浏览器 PID，工具自动完成：

1. 获取进程信息；
2. 判断是否为浏览器子进程；
3. 沿父进程链向上查找浏览器主进程；
4. 查找同一浏览器实例的顶层窗口；
5. 获取当前前台窗口；
6. 对比调用进程与浏览器主进程的权限；
7. 判断是否可能被 UIPI、Session 或桌面隔离阻断。

示例：

```
wpsi.exe browser --network-pid 9824
```

6. 功能需求

6.1 进程基础信息采集

对每个目标进程，至少采集：

字段	说明
Process Name	进程名称

字段	说明
PID	当前进程 ID
Parent PID	父进程 ID
Executable Path	可执行文件完整路径
Command Line	启动命令行
Process Start Time	进程启动时间
Architecture	x86、x64、ARM64
Session ID	所属 Session
Priority Class	基本优先级
Thread Count	线程数量
Handle Count	句柄数量
Is In Job	是否处于 Job Object
Service Name	如属于服务，显示服务名称

6.2 用户身份信息采集

对进程 Token 采集：

字段	说明
User Name	用户名
Domain	用户域
User SID	用户 SID
Logon SID	登录会话 SID
Authentication ID	登录认证 LUID
Is LocalSystem	是否为 SYSTEM
Is LocalService	是否为 LocalService
Is NetworkService	是否为 NetworkService
Is Interactive User	是否为交互登录用户
Token Type	Primary 或 Impersonation

典型 SID 应识别为可读名称：

```
S-1-5-18 LocalSystem
S-1-5-19 LocalService
S-1-5-20 NetworkService
```

6.3 Integrity Level 检测

工具必须读取：

```
TokenIntegrityLevel
```

并映射为：

- Untrusted
- Low
- Medium
- Medium Plus
- High
- System
- Protected Process

输出原始 RID 和可读名称。

示例：

```
Integrity Level : Medium
Integrity RID   : 0x00002000
```

6.4 UAC 和 Elevation 检测

工具必须采集：

```
TokenElevation
TokenElevationType
TokenLinkedToken
```

输出：

字段	说明
Elevated	当前是否已提升
Elevation Type	Default、Full、Limited

字段	说明
Has Linked Token	是否存在关联 Token
Linked Token IL	关联 Token 的完整性级别
UAC Split Token	是否为管理员拆分令牌

典型结果：

```
Elevated      : No
Elevation Type : Limited
Integrity     : Medium
```

或：

```
Elevated      : Yes
Elevation Type : Full
Integrity     : High
```

6.5 管理员权限检测

工具应区分：

- 用户是否属于 Administrators 组；
- 当前 Token 中管理员 SID 是否启用；
- 管理员 SID 是否为 Deny-Only；
- 当前进程是否实际以管理员权限运行。

输出示例：

```
Administrator Member : Yes
Administrator Enabled: No
Administrator SID    : Deny-Only
```

避免仅通过 `IsUserAnAdmin()` 得出不准确结论。

6.6 Token 特权检测

读取进程 Token 中的权限列表：

```
SeDebugPrivilege
SeImpersonatePrivilege
SeTcbPrivilege
```

```
SeAssignPrimaryTokenPrivilege
SeIncreaseQuotaPrivilege
SeLoadDriverPrivilege
SeCreateGlobalPrivilege
SeSecurityPrivilege
```

每项标识：

- Present
- Enabled
- Disabled
- Removed

重点对以下权限给出提示：

```
SeDebugPrivilege
SeImpersonatePrivilege
SeAssignPrimaryTokenPrivilege
SeIncreaseQuotaPrivilege
SeLoadDriverPrivilege
```

6.7 UIAccess 检测

读取：

```
TokenUIAccess
```

输出：

```
UIAccess : Yes / No
```

同时检查：

- 程序是否位于受信任目录；
- EXE 是否有数字签名；
- Manifest 是否声明 `uiAccess="true"`。

工具只做检测，不自动修改。

6.8 AppContainer 检测

读取：

```
TokenIsAppContainer
TokenAppContainerSid
TokenCapabilities
```

输出：

- 是否为 AppContainer；
- AppContainer SID；
- Capability SID；
- 是否为浏览器沙箱子进程。

用于识别 Chrome、Edge 等受限子进程。

6.9 Session 检测

工具必须采集：

- Process SessionId；
- 当前活动控制台 Session；
- 当前交互用户 Session；
- Session 状态；
- Session 用户；
- Session 是否锁定；
- 是否为 Session 0。

输出示例：

```
Process Session : 0
Active Session  : 1
Interactive User: DOMAIN\user
```

出现以下情况应标为严重异常：

```
服务进程位于 Session 0
浏览器位于 Session 1
服务尝试直接操作浏览器窗口
```

6.10 Window Station 和 Desktop 检测

工具应获取进程关联的：

- Window Station；
- Desktop；
- 当前线程 Desktop；

- 目标窗口 Desktop;
- 当前输入 Desktop。

输出示例:

```
Window Station : WinSta0
Desktop       : Default
```

应识别以下异常:

```
xianc2      : WinSta0\Default
browser     : WinSta0\Default
service     : Service-0x0-3e7$\Default
```

不同 Window Station 或 Desktop 的进程不能直接进行正常桌面交互。

6.11 进程优先级检测

采集:

```
GetPriorityClass
GetThreadPriority
```

映射为:

- Idle
- Below Normal
- Normal
- Above Normal
- High
- Realtime

同时检查:

- 是否调用后台模式;
- 是否由父进程继承;
- 是否由任务计划程序设置;
- 是否处于资源限制 Job Object。

输出示例:

```
Priority Class : Below Normal
```

并提示:

可能导致高负载下认证事件处理延迟，但不会直接造成 UAC 权限拒绝。

6.12 Job Object 检测

工具应检测：

```
IsProcessInJob
QueryInformationJobObject
```

采集：

- 是否加入 Job Object；
- CPU 限制；
- 内存限制；
- 活跃进程限制；
- UI 限制；
- Kill-on-job-close；
- 优先级限制。

6.13 进程父子关系分析

工具必须构建进程树：

```
explorer.exe
└─ xianc2.exe
```

或：

```
service.exe
└─ launcher.exe
   └─ xianc2.exe
```

对 Chrome/Edge 应支持：

```
chrome.exe 主进程
├─ renderer
├─ gpu-process
├─ utility
└─ network-service
```

要求支持：

- 向上追溯父进程；
- 向下列出子进程；
- 显示启动时间；
- 判断父 PID 是否已被复用；
- 显示每个进程的命令行参数。

6.14 浏览器主进程识别

针对 Chrome、Edge、Firefox，工具应识别：

- 主进程；
- Renderer；
- Network Service；
- GPU Process；
- Utility Process；
- Crash Handler；
- Extension Process。

识别依据包括：

- 进程名；
- 父子关系；
- 命令行参数；
- 顶层窗口；
- 创建时间；
- User Data Directory；
- Session；
- User SID。

Chrome/Edge 子进程常见参数：

```
--type=renderer  
--type=utility  
--type=gpu-process  
--utility-sub-type=network.mojom.NetworkService
```

主进程通常不带 `--type=` 参数。

工具必须输出：

```
Input PID           : 9824  
Detected Role       : Network Service  
Browser Main PID    : 4312  
Browser Window HWND : 0x000A04F2
```

6.15 顶层窗口检测

工具应枚举目标进程相关窗口：

- HWND；
- 窗口标题；
- Window Class；
- 可见状态；
- 最小化状态；
- 是否前台窗口；
- 所属 PID；
- 所属线程；
- 窗口 Desktop；
- 是否为 Tool Window；
- 是否有 Owner Window。

支持判断：

- 目标 PID 是否存在可见顶层窗口；
- WFP PID 是否只是无窗口的浏览器子进程；
- 浏览器主进程是否拥有窗口；
- 当前前台浏览器窗口属于哪个 PID。

6.16 前台交互能力判断

工具应综合判断当前进程是否有能力：

- 找到目标浏览器窗口；
- 切换前台窗口；
- 调用 `SendInput` ；
- 发送窗口消息；
- 操作剪贴板；
- 在目标桌面显示 UI。

判断规则至少包括：

1. Session 是否相同；
2. User SID 是否相同；
3. Window Station 是否相同；
4. Desktop 是否相同；
5. 调用方 IL 是否低于目标 IL；
6. 目标是否为 AppContainer；
7. 调用方是否具有 UIAccess；
8. 是否存在前台切换限制；
9. 是否为服务 Session；
10. 是否存在 UIPI 限制。

6.17 UIPI 风险判断

工具应自动比较调用方与目标进程的 Integrity Level。

典型规则：

调用方 Medium，目标 High

输出：

High Risk:

调用方完整性级别低于目标进程，SendInput、窗口消息或自动化控制可能受到 UIPI 限制。

调用方 High，目标 Medium

输出：

No IL Barrier:

未发现由完整性级别导致的单向 UIPI 阻断。

说明：最终操作是否成功仍受前台窗口策略和目标程序行为影响。

6.18 AppCompat 配置检测

检查以下注册表：

HKCU\Software\Microsoft\Windows NT\CurrentVersion\AppCompatFlags\Layers
HKLM\Software\Microsoft\Windows NT\CurrentVersion\AppCompatFlags\Layers

识别：

- RUNASADMIN
- RUNASINVOKER
- RunAsHighest
- RunAsRevoke
- WINXPSP3
- DISABLETHEMES
- HIGHDPIAWARE

工具应显示目标 EXE 是否受到兼容层影响。

6.19 Manifest 检测

读取 EXE Manifest，识别：

```
requestedExecutionLevel  
uiAccess
```

支持以下级别：

```
asInvoker  
highestAvailable  
requireAdministrator
```

输出：

```
Manifest Execution Level : asInvoker  
Manifest UIAccess       : false
```

6.20 可执行文件签名检测

采集：

- 是否有 Authenticode 签名；
- 签名是否有效；
- 签名者；
- 证书颁发者；
- 时间戳；
- 文件哈希。

该能力用于辅助判断 UIAccess、企业安全策略和文件可信性。

6.21 服务信息检测

当进程属于 Windows Service 时，输出：

- 服务名称；
- Display Name；
- 启动类型；
- 服务账户；
- Service Type；
- 是否允许交互桌面；
- 服务 Session；
- 服务状态；
- 是否延迟启动；

- 是否由 SCM 启动。

6.22 自启动来源检测

工具应尽量识别进程启动来源：

- 注册表 Run；
- 注册表 RunOnce；
- Startup 文件夹；
- 任务计划程序；
- Windows Service；
- 安装程序启动器；
- 父进程；
- 用户手工启动；
- ShellExecute `runas`。

重点检测：

HKCU\Software\Microsoft\Windows\CurrentVersion\Run
HKLM\Software\Microsoft\Windows\CurrentVersion\Run

任务计划程序需输出：

- 任务名称；
- Run Level；
- Logon Type；
- Priority；
- 是否仅用户登录时运行；
- 是否使用最高权限运行。

6.23 自动诊断规则

工具应至少实现以下规则。

规则 1：完整性级别低于浏览器

xianc2 IL < browser IL

结论：

可能受到 UIPI 限制。

规则 2: Session 不一致

```
xianc2 SessionId != browser SessionId
```

结论:

无法可靠进行直接桌面交互。

规则 3: 用户 SID 不一致

```
xianc2 User SID != browser User SID
```

结论:

进程属于不同用户安全上下文，应通过用户态 Agent 或 IPC 协作。

规则 4: 服务位于 Session 0

```
process SessionId == 0
```

结论:

服务进程不应直接弹出用户界面或控制浏览器。

规则 5: 目标 PID 为浏览器子进程

```
--type=renderer  
--type=utility  
--type=gpu-process
```

结论:

该 PID 不是浏览器主进程，不能直接用于顶层窗口定位。

规则 6: 无顶层窗口

目标 PID 未发现可见顶层窗口

结论:

应继续向父进程或同实例主进程查找。

规则 7：程序为 Medium 且需要管理员能力

若检测到程序调用或配置涉及：

- WFP 策略写入；
- 服务控制；
- 驱动加载；
- HKLM 写入；
- Program Files 写入；

但进程为 Medium、Limited，则提示权限不足风险。

规则 8：进程优先级低于正常

输出：

可能造成高负载下处理延迟，但不属于 UAC 或 Integrity Level 权限问题。

规则 9：存在兼容性层

检测到：

RUNASADMIN
RUNASINVOKER
RunAsRevoke

输出覆盖行为和潜在影响。

规则 10：不同 Desktop

调用方 Desktop != 目标 Desktop

结论：

无法直接进行可靠窗口交互。

7. 诊断结果等级

诊断项分为四级：

等级	含义
INFO	信息项，无异常
NOTICE	值得关注，但不一定影响功能
WARNING	可能造成功能异常
ERROR	已发现明确不兼容条件
CRITICAL	无法进行目标操作

示例：

```
ERROR:
fjAccessControl 位于 Session 0, Chrome 位于 Session 1。

WARNING:
xianc2 完整性级别为 Medium, Chrome 为 High。

NOTICE:
xianc2 基本优先级为 Below Normal。
```

8. 输出格式

工具应支持以下格式：

- 控制台文本；
- JSON；
- Markdown；
- HTML；
- 日志文件。

命令示例：

```
wpsi.exe inspect --format json --output result.json
```

```
wpsi.exe compare xianc2.exe chrome.exe --format markdown
```

JSON 应适合集成到 `xianc2` 日志或远程诊断平台。

9. 推荐报告结构

1. 系统概况
2. 当前交互用户

3. 活动 Session
4. 目标进程列表
5. 每个进程的安全上下文
6. 进程树
7. 浏览器进程角色识别
8. 顶层窗口列表
9. 权限差异对比
10. 自动诊断结论
11. 风险等级
12. 修复建议

10. 示例输出

```
[Process]
Name           : xianc2.exe
PID            : 4520
Parent PID     : 3188
Path           : C:\Program Files\TrustMore\xianc2.exe
User           : DOMAIN\user
User SID       : S-1-5-21-...
Session ID     : 1
Integrity Level : Medium
Elevated       : No
Elevation Type : Limited
Administrator Member : Yes
Administrator Enabled : No
UIAccess       : No
AppContainer   : No
Window Station : WinSta0
Desktop        : Default
Priority Class  : Below Normal
In Job Object  : No
Architecture   : x64
```

```
[Browser]
Input PID      : 9824
Process Name   : chrome.exe
Role           : Network Service
Main Browser PID : 4312
Top-Level Window : 0x001A05C4
Window Title   : Google Chrome
Session ID     : 1
User SID       : S-1-5-21-...
Integrity Level : Medium
```

[Diagnosis]

INFO:

xianc2 与 Chrome 位于同一 Session。

INFO:

xianc2 与 Chrome 使用相同 User SID。

INFO:

xianc2 与 Chrome 均位于 WinSta0\Default。

NOTICE:

xianc2 基本优先级为 Below Normal，可能导致高负载下响应延迟。

WARNING:

输入 PID 9824 为 Chrome Network Service，不是浏览器主进程。

RESULT:

未发现 Integrity Level、Session 或 User SID 导致的窗口交互阻断。

11. 图形界面需求

图形界面建议包含以下区域。

11.1 进程列表

显示：

- 名称；
- PID；
- 用户；
- Session；
- Integrity Level；
- Elevation；
- 架构；
- 优先级。

支持排序、筛选和刷新。

11.2 进程详情

按页签展示：

- General；
- Token；
- Privileges；
- Session；
- Desktop；

- Windows;
- Parent Tree;
- Browser Role;
- Compatibility;
- Signature;
- Diagnosis。

11.3 对比视图

允许选择两个或多个进程，突出差异：

xianc2.exe	Chrome.exe
Medium	High
Session 1	Session 1
User A	User A
Default Desktop	Default Desktop

不同项高亮显示。

11.4 诊断结论

显示：

- 结论；
- 风险等级；
- 证据；
- 可能影响；
- 建议处理方式。

12. 命令行接口需求

建议命令：

```
wpsi inspect
wpsi inspect --pid <pid>
wpsi inspect --name <process>
wpsi compare --pid <pid1> --pid <pid2>
wpsi browser --network-pid <pid>
wpsi sessions
wpsi windows --pid <pid>
wpsi tree --pid <pid>
wpsi export --format json
```

支持参数：

```
--pid
--name
--all
--browser
--include-children
--include-windows
--include-token
--include-privileges
--format
--output
--verbose
```

13. 集成接口需求

工具核心能力应封装为独立静态库或动态库。

建议模块：

```
process_inspector
token_inspector
session_inspector
desktop_inspector
window_inspector
browser_inspector
compatibility_inspector
diagnosis_engine
report_exporter
```

建议接口：

```
ProcessSecurityContext inspect_process(DWORD pid);
BrowserProcessContext inspect_browser_process(DWORD pid);
ComparisonResult compare_processes(DWORD sourcePid, DWORD targetPid);
DiagnosisReport diagnose_interaction(DWORD sourcePid, DWORD targetPid);
```

可供 `xianc2` 调用：

```
auto report = diagnose_interaction(
    GetCurrentProcessId(),
    browser_pid);
```

14. 权限要求

工具普通模式应以普通用户运行，并尽量获取同一用户进程信息。

对于以下情况，可能需要管理员权限：

- 查询其他用户进程；
- 查询 SYSTEM 进程；
- 获取受保护进程 Token；
- 获取完整命令行；
- 读取服务配置；
- 读取部分任务计划；
- 启用 `SeDebugPrivilege`。

工具不得默认要求管理员权限，应按需提示：

部分进程信息无法读取。建议以管理员身份重新运行以获得完整结果。

15. 安全要求

1. 工具只读取信息，不修改 Token；
2. 不提升目标进程权限；
3. 不注入目标进程；
4. 不绕过 UIPI；
5. 不关闭安全软件；
6. 不修改 UAC 设置；
7. 不修改兼容性注册表；
8. 导出报告时默认隐藏敏感命令行参数；
9. 用户 SID、用户名和路径支持脱敏；
10. 日志中不得输出密码、Token、Cookie、认证密钥。

16. 兼容性要求

支持：

- Windows 10 x64；
- Windows 11 x64；
- 普通用户；
- 管理员用户；
- UAC 开启和关闭环境；
- 多用户登录；
- 远程桌面 Session；
- Chrome；
- Edge；
- Firefox；
- Qt 5/C++20 项目集成。

17. 性能要求

- 单进程基础诊断不超过 200 毫秒；
 - 全系统进程扫描不超过 3 秒；
 - 浏览器进程树识别不超过 1 秒；
 - 不应持续占用高 CPU；
 - 默认不进行周期性监控；
 - 实时监控模式刷新周期不低于 1 秒；
 - 工具退出后不得残留后台进程。
-

18. 验收标准

18.1 基础采集验收

工具能够正确输出指定进程的：

- PID；
- Parent PID；
- User SID；
- SessionId；
- Integrity Level；
- Elevation；
- Elevation Type；
- UIAccess；
- Priority Class；
- Window Station；
- Desktop。

18.2 UAC 场景验收

同一程序分别通过：

- 普通启动；
- 管理员启动；

工具应正确识别：

Medium + Limited
High + Full

18.3 Session 0 验收

对 Windows Service 应识别：


```
SessionId = 0
User = SYSTEM
```

并提示不能直接操作用户浏览器。

18.4 浏览器多进程验收

输入 Chrome Network Service PID，工具应找到：

- 子进程角色；
- Chrome 主进程；
- 主窗口 HWND；
- 主进程权限信息。

18.5 UIPI 验收

构造：

```
诊断工具 Medium
目标进程 High
```

工具应输出 UIPI 风险提示。

18.6 用户不一致验收

两个不同用户启动进程时，工具应识别 User SID 不同。

18.7 Desktop 不一致验收

服务桌面与用户桌面不一致时，工具应输出明确错误。

18.8 优先级验收

将进程设置为 Below Normal 后，工具应正确显示，并区分其与权限问题。

18.9 AppCompat 验收

为测试程序配置：

```
RUNASADMIN
RUNASINVOKER
RunAsRevoke
```

工具应正确读取并解释。

18.10 报告导出验收

同一次诊断能够导出：

- JSON；
 - Markdown；
 - HTML。
-

19. 开发优先级

第一阶段：最小可用版本

实现：

- PID 和进程路径；
- Parent PID；
- User SID；
- SessionId；
- Integrity Level；
- Elevation；
- Elevation Type；
- Priority Class；
- 进程对比；
- 文本和 JSON 输出。

第二阶段：浏览器专项

实现：

- Chrome/Edge 子进程角色识别；
- 浏览器主进程查找；
- 顶层窗口定位；
- 当前前台窗口；
- UIPI 和 Session 自动判断。

第三阶段：完整诊断

实现：

- Window Station；
- Desktop；
- UIAccess；
- AppContainer；
- Token Privileges；
- Job Object；
- Manifest；
- AppCompat；
- 服务和任务计划来源。

第四阶段：产品化

实现：

- Qt 图形界面；
- HTML 报告；
- xianc2 集成；
- 一键采集现场诊断包；
- 诊断规则配置化；
- 日志脱敏。

20. 推荐的最小版本结论

第一版不必一次实现全部能力。最小版本应优先解决当前问题：

1. 当前 xianc2 的安全上下文；
2. fjAccessControl 的安全上下文；
3. explorer.exe 的安全上下文；
4. WFP 获取到的浏览器 PID；
5. 浏览器主进程 PID；
6. 浏览器窗口 PID；
7. Integrity Level 对比；
8. Elevation 对比；
9. SessionId 对比；
10. User SID 对比；
11. Window Station 和 Desktop 对比；
12. 自动生成是否存在 UIPI 或 Session 隔离问题的结论。

该最小版本已经能够覆盖大部分：

开机自启动异常
管理员启动正常
无法弹认证页
无法控制浏览器
WFP PID 不对应浏览器窗口

等问题。